

TeamPCP Campaign Analysis

Phases 7–9: Post-Compromise Operations (18 March – Early April 2026)

Classification: TLP:WHITE | Prepared for internal threat-intelligence use

4.12 Phase 7 — Post-Telnyx Victim Expansion and Operationalization (31 March – 8 April 2026)

The Telnyx PyPI compromise on 27 March 2026 marked the last confirmed upstream package poisoning event in the initial wave of TeamPCP activity. What followed was not dormancy but a deliberate operational pivot: the actor shifted from ecosystem compromise toward the systematic exploitation of credentials already stolen during Phases 1 through 6. Between 31 March and 8 April 2026, public reporting documented the first confirmed downstream victim disclosures, the first formal government-level breach confirmation, and the formal classification of the intrusion set by Google Threat Intelligence Group. This period is analytically distinct because the locus of harm moved entirely off the package registries and into the victim environments those registries had been used to penetrate. SANS reporting noted that as of 8 April this represented the longest pause in confirmed upstream package compromises since the campaign began, while downstream victim disclosures continued to accumulate. The appropriate analytic framing is that TeamPCP had reached exploitation sufficiency: enough credentials had been harvested to sustain a downstream intrusion campaign without returning immediately to upstream poisoning channels.

4.12.1 31 March 2026 — Mercor Confirms LiteLLM-Derived Compromise

On 31 March 2026, Mercor publicly confirmed that it had been affected by the LiteLLM supply chain compromise. TechCrunch reported Mercor's statement that it was "one of thousands of companies" impacted by the weaponised LiteLLM release. The Mercor disclosure is important for several technical reasons beyond simply confirming a downstream victim.

LiteLLM functions as a proxy routing layer that aggregates requests to multiple large language model providers simultaneously — OpenAI, Anthropic, Cohere, and others — meaning a single LiteLLM deployment routinely holds API keys for **multiple commercial AI providers** within a single configuration or environment file. A credential harvest from a LiteLLM installation therefore potentially yields multiple independently usable secrets in a single operation, each independently monetizable or exploitable for compute resource abuse, rather than a single service token.

The affected environment reportedly included sensitive recruiting and identity-verification data, which illustrates how a dependency-level compromise in developer infrastructure can produce immediate privacy and business impact downstream for end users who had no direct relationship with the compromised package. For the purposes of this report, Mercor represents the first confirmed victim disclosure that moves the campaign's downstream impact from theoretical to proven: it validates that LiteLLM-phase credentials were not merely collected but operationalized against real victim environments.

4.12.2 31 March 2026 — ownCloud Discloses Trivy-Linked Build Infrastructure Exposure

ownCloud publicly disclosed on 31 March 2026 that [CVE-2026-33634](#) had affected its build infrastructure through the Trivy supply chain compromise. Critically, ownCloud stated that the impact was limited to build pipeline exposure and that no customer data had been compromised and no source code had been altered or trojanized.

Build infrastructure exposure in a CI/CD context means specifically that build-time credentials, package signing keys, or deployment tokens were potentially accessible to the malicious package during the build execution window — it does not necessarily mean that any built artifact was modified or that downstream software customers received compromised binaries. This distinction carries different risk implications for different categories of ownCloud's user base: customers of ownCloud's hosted service face a different exposure profile than customers of ownCloud's self-hosted software releases, because the vectors of potential harm diverge depending on whether the relevant risk is credential theft from build systems or supply-chain trojanization of distributed packages. The ownCloud case therefore supports a tiered victim impact model that the report should maintain consistently: build-credential exposure, cloud environment intrusion, data exfiltration, and extortion-style pressure are distinct impact categories that should not be conflated.

4.12.3 Early April 2026 — Cisco Development Environment Breach Reported

By 8 April 2026, SANS Update 007 summarized credible third-party reporting that Cisco had suffered a breach of its development environment linked to the Trivy supply chain compromise, with attackers allegedly exfiltrating source code and cloning more than 300 internal repositories. At the time of writing, this reporting has not been confirmed through a public vendor self-disclosure by Cisco and should therefore be characterized as strongly reported rather than formally confirmed.

The technical significance of the Cisco case, if accurate, extends beyond immediate intellectual property loss. Access to proprietary source code repositories enables extended offline vulnerability research against codebases that external researchers cannot normally inspect: an attacker with cloned repositories from a major networking and security vendor can analyze code at leisure, without triggering any detection on Cisco's side, searching for exploitable flaws in products that are widely deployed across critical infrastructure environments. This converts a supply chain compromise into a persistent strategic intelligence asset of a qualitatively different kind from cloud credential theft, because the downstream risk compounds over time as the actor mines the exfiltrated code for exploitable conditions.

4.12.4 2–3 April 2026 — European Commission / CERT-EU Cloud Breach Confirmed

CERT-EU confirmed with high confidence that the European Commission's cloud environment, associated with the Europa web hosting platform, had been breached through the TeamPCP-linked Trivy supply chain compromise. CERT-EU assessed that the initial access vector was a

compromised AWS API key obtained via the malicious Trivy package during the 19 March exploitation window.

Approximately **91.7 GB compressed (approximately 340 GB uncompressed)** was exfiltrated from the affected environment, giving a compression ratio of approximately 3.7:1. That ratio is consistent with the data being primarily text, structured records, or email content rather than binary or media files — consistent with CERT-EU's separate confirmation that tens of thousands of outbound email-related files were among the exposed material.

The breach affected websites and data associated with 42 internal European Commission clients and at least 29 additional Union entities hosted on the shared Europa platform, with confirmed exposure of names, usernames, and email addresses. The European Commission case is the highest-confidence, highest-profile government-linked downstream victim confirmation in the campaign and is the clearest available demonstration that the March 2026 package compromises produced direct, large-scale, institutional harm.

4.12.5 Early April 2026 — Sportradar and Additional Victim Claims

SANS Update 006 reported emerging details around Sportradar, and public campaign-tracking pages listed additional organizations across sports, healthcare, and pharmaceutical sectors as direct victims or credential-exposure victims. These disclosures vary substantially in evidentiary quality. Several appear primarily in extortion-side announcements, adversary-maintained public victim lists, or early reporting without equivalent primary confirmation.

This matters because TeamPCP and associated aliases, including CipherForce and Vect, have used public victim announcements and deadline-style messaging as deliberate pressure operations. Treating adversary-maintained victim lists as equivalent in confidence to CERT-EU or primary vendor self-disclosures would risk laundering adversary claims into the report's findings. The report should preserve a three-tier confidence structure:

- **Confirmed victims** — official or regulatory-grade disclosure (e.g. Mercor, ownCloud, European Commission via CERT-EU).
- **Strongly reported victims** — credible security-vendor coverage without primary self-disclosure (e.g. Cisco).
- **Claimed or partially corroborated victims** — appearing primarily in extortion-side or tracker-based reporting (e.g. some sports and healthcare entities).

4.12.6 Formal Threat Tracking — UNC6780 and SANDCLOCK

By 8 April 2026, Google Threat Intelligence Group was formally tracking TeamPCP under the intrusion set designation **UNC6780** and its primary credential-stealing payload as **SANDCLOCK**. The analytic significance of this formalization is threefold.

First, the UNC designation indicates that Google assessed the campaign as a sufficiently stable and coherent threat cluster to merit a persistent tracking identifier rather than treatment as a series of loosely connected incidents. Second, the naming of SANDCLOCK as a distinct malware family means the credential-harvesting payload is now addressable as a stable detection target across vendors, enabling more coherent YARA rule development, cross-vendor threat-intelligence

sharing, and retrospective incident clustering. Third, GTIG simultaneously distinguished TeamPCP and UNC6780 from unrelated activity such as the Axios package compromise, which was circulating in parallel reporting — a clarification that reduces analytic conflation across different campaign threads.

SANDCLOCK should be understood specifically as the credential-harvesting payload embedded in the malicious packages, distinct from the post-compromise tooling — TruffleHog, AWS CLI enumeration calls, and similar utilities — that the actor deployed after exfiltrating those credentials into operator-controlled infrastructure. The malware family label applies to the stealer; the post-compromise cloud activity represents operator tradecraft using commodity and cloud-native tools, not the SANDCLOCK payload itself.

4.12.7 Victim-Environment Tradecraft — Credential Validation and Cloud Reconnaissance

Wiz's post-compromise reporting documented a disciplined, sequenced post-exploitation workflow that began within hours of initial credential theft and continued through cloud-environment mapping within approximately 24 hours of the initial compromise activity. This four-stage sequence — validate, enumerate, persist, exfiltrate — is consistent across the Wiz findings and the CERT-EU European Commission case study and represents the actor's standard post-theft operational playbook.

Credential Validation

The actor used the open-source secret scanner **TruffleHog**, almost certainly in verify mode (**--only-verified**), which actively tests harvested credentials against live provider APIs rather than simply pattern-matching against known secret formats. This is a deliberate operational choice: running TruffleHog in verify mode eliminates false positives immediately, surfaces only usable live credentials, and reduces the time required to triage a large harvest.

For AWS credentials, validation was performed via **sts:GetCallerIdentity**. This call requires no special IAM permissions to invoke, meaning even heavily restricted or scoped-down keys can be validated without generating permission-denied errors that might alert defenders or trigger automated response. The call returns the account ID, the user or role ARN, and the user ID — sufficient to confirm key validity and identify the principal's privilege context before proceeding to riskier enumeration. The same validation workflow was applied against Azure application secrets and SaaS tokens.

AWS Control-Plane Discovery

After validation, the actor transitioned to AWS control-plane discovery. Wiz documented enumeration of IAM (**ListUsers**, **ListRoles**, **ListAttachedUserPolicies**), EC2 (**DescribeInstances**), and Lambda (**ListFunctions**). SANS synthesis of the Wiz findings adds RDS, S3, and ECS to the discovery surface, with particular focus on container infrastructure and task definitions.

ListAttachedUserPolicies reveals which managed policies a principal holds — a prerequisite for privilege-escalation path analysis. Pairing that result with **ListRoles** allows the actor to

identify assumable roles, which is the next logical step toward lateral movement within the account.

ListFunctions targeting Lambda is not only compute discovery: Lambda functions frequently store hardcoded API keys, database connection strings, and service tokens in environment variables, making them a **secondary credential source** within an already-compromised account — credential harvesting at a second layer. This overall discovery sequence maps to a recognizable cloud attacker playbook sometimes described as **blast-radius mapping**: determining how far the initially obtained credential can reach before committing to actions that generate more conspicuous log volume.

Operator Naming Artifacts

Wiz additionally documented that TeamPCP's post-compromise cloud operations included operationally distinctive resource naming, with strings such as "**pawn**" and "**massive-exfil**" appearing in attacker-created cloud resource names. These strings appear in AWS CloudTrail as values in **requestParameters** fields such as **bucketName**, EC2 resource tags, or IAM entity names, making them huntable via **aws cloudtrail lookup-events** or equivalent SIEM queries.

Defenders should note, however, that attacker-chosen resource names at the S3 object or data-event level are only visible in CloudTrail if data event logging has been explicitly enabled alongside management event logging: organizations without data event logging configured would see management-plane API calls but would not see S3-level object operations.

4.12.8 Campaign Tempo Shift — The Supply Chain Pause

As of 3 April 2026, SANS Update 006 noted that no new TeamPCP-linked package compromise had been publicly confirmed since the Telnix incident on 27 March. By 8 April, SANS Update 007 described this as approximately a 24-day pause — the longest such gap since the campaign began in mid-February 2026. The absence of new upstream compromises does not indicate campaign dormancy and should not be interpreted as such.

The more accurate framing, consistent with the observed downstream activity during the same period, is that the actor had accumulated sufficient stolen access to sustain a downstream exploitation phase without immediately needing to return to upstream poisoning. Publisher tokens, GitHub credentials, cloud API keys, CI/CD secrets, and service tokens harvested during Phases 1 through 6 provided a working inventory of validated access that could be operationalized sequentially. The supply chain pause is therefore better understood as an operational tempo shift reflecting exploitation sufficiency than as a sign of attrition or disruption.

4.13 Phase 8 — Downstream Cloud Exploitation and Persistence (19 March – Early April 2026)

The European Commission breach, as documented by CERT-EU, provides the most technically detailed confirmed case study of TeamPCP's downstream exploitation methodology and is treated as the primary analytical reference for this phase. Where the earlier phases of the

campaign demonstrated how TeamPCP poisoned trusted distribution channels and harvested secrets from developer and CI/CD environments, Phase 8 documents what the actor did with those secrets inside victim cloud environments: a sequenced workflow of credential validation, control-plane discovery, persistence establishment through credential expansion, and large-scale data exfiltration. This phase is where the supply chain campaign converted into a cloud intrusion campaign, and it is the clearest available demonstration that package remediation and registry cleanup are insufficient responses once the actor has cleared the credential-validation stage and begun operating inside victim environments.

4.13.1 Initial Access and Credential Reuse

CERT-EU confirmed that the actor obtained an AWS API key through the Trivy supply chain compromise on 19 March 2026 and used it the same day for follow-on activity. The first documented post-theft action was execution of **TruffleHog** to discover and validate additional secrets within the victim environment, with **sts:GetCallerIdentity** used for AWS key validation — independently corroborating Wiz's broader findings about the actor's credential-triage workflow and confirming that this validation behavior occurred inside a real victim environment rather than only in operator-controlled infrastructure.

This is technically significant because it shows the actor using the initially compromised principal's own access to surface additional secrets within the same environment, extending the credential harvest beyond what was obtained through the package compromise itself.

4.13.2 Persistence Through Credential Expansion

CERT-EU reported that after establishing initial access, the actor used the compromised AWS secret to create and attach a new access key to an existing IAM user. Creating a new key via **iam:CreateAccessKey** on an existing user generates a second, independent credential pair that remains valid even if the originally stolen key is subsequently identified and revoked: revocation of the stolen key alone does not remove the actor's access, because the newly created key is a separate credential object with its own access key ID and secret.

Attaching the new key to an **existing** user rather than creating a new IAM user is a lower-noise variation of this technique: it avoids generating **CreateUser** CloudTrail events, which are more commonly monitored or alerted on in hardened environments, and it inherits the existing user's already-attached managed and inline policies without requiring a separate **AttachUserPolicy** or **PutUserPolicy** call. This makes the persistence action difficult to distinguish from a legitimate key rotation unless the creating principal and source IP are inspected.

AWS enforces a hard limit of two active access keys per IAM user, which provides a compensating detection opportunity: any IAM user observed transitioning from one to two active access keys — particularly where the second key is created by a different principal or from an unrecognized source IP or User-Agent — should be treated as a high-priority indicator. The relevant CloudTrail event type is **CreateAccessKey**, and monitoring for this event on any principal other than the key-holder themselves or a known IAM administrator should be a baseline detection rule in cloud environments handling sensitive data.

4.13.3 Reconnaissance and Data Exfiltration

Following persistence establishment, CERT-EU confirmed that the actor conducted reconnaissance across the victim environment and exfiltrated approximately 91.7 GB compressed (340 GB uncompressed) of data. The compression ratio of approximately 3.7:1 is consistent with the exfiltrated material being primarily text, structured records, or email content rather than binary or media files — consistent with CERT-EU's separate confirmation that tens of thousands of outbound email-related files were among the exposed material.

The affected scope included websites and associated data for 42 internal European Commission clients and at least 29 additional Union entities hosted on the shared Europa web platform, with confirmed exposure of names, usernames, and email addresses. The breadth of victim-entity impact is consistent with the actor having obtained access to a shared hosting control plane: a single compromised credential in a shared cloud hosting environment can provide access to data belonging to multiple tenants if the account structure does not enforce per-tenant isolation at the IAM boundary, which means the initial credential compromise had a multiplied downstream impact across entities that had no individual exposure to the malicious package.

4.13.4 Detection Signals and Response

CERT-EU identified three categories of detection signal in the European Commission case: potential misuse of Amazon APIs, potential account compromise, and an abnormal increase in network traffic. In technical terms, these signals likely manifested as follows.

API misuse signal: Probable `sts:GetCallerIdentity` and subsequent IAM enumeration calls (`ListUsers`, `ListRoles`, `ListAttachedUserPolicies`) originating from unrecognized source IP addresses or with unusual User-Agent strings, occurring in rapid succession in CloudTrail.

Account compromise signal: Likely triggered by a `CreateAccessKey` event on an existing user attributable to an unexpected principal, representing a deviation from the account's normal key management behavior.

Network traffic anomaly: In a cloud context this typically manifests as elevated S3 `GetObject` call volumes or an unusual egress spike visible in S3 server access logs or VPC Flow Logs, rather than as a signature match in a traditional network IDS.

CERT-EU additionally noted that no lateral movement between AWS accounts had been identified at the time of publication, despite the actor having obtained management-level access that could have enabled cross-account operations. This may reflect time pressure following detection, a deliberate decision to limit operational scope and reduce further detection risk, or the actor not yet having completed its primary objectives before incident response began. It should not be interpreted as evidence of operational restraint as a norm.

4.14 Phase 9 — Analytic Assessment: From Supply Chain Campaign to Persistent Cloud Intrusion Threat

The post-28 March evidence establishes that TeamPCP should no longer be analyzed solely as a software supply chain actor. The campaign that began with GitHub Actions token theft in mid-February 2026 had by early April evolved into a demonstrated cloud intrusion operation, using supply chain access as the entry mechanism for credential theft and those credentials as the entry mechanism for downstream cloud exploitation, data exfiltration, and coercive pressure operations. The supply chain phases were instrumentally important as the collection mechanism, but the strategic risk lies in the downstream intrusion phase they enabled.

Three analytic conclusions follow from the Phase 7 through Phase 9 evidence.

First, the tempo shift after Telnix reflects sufficiency of access rather than loss of capability: the actor had accumulated enough credentials across Phases 1 through 6 to sustain a downstream exploitation campaign without continuing upstream poisoning at the same pace.

Second, the post-compromise workflow documented by Wiz and CERT-EU — validate, enumerate, persist, exfiltrate — is structured and repeatable, not opportunistic, indicating an actor operating a disciplined intrusion playbook rather than conducting ad hoc exploitation.

Third, package remediation and removal of malicious versions from registries is necessary but insufficient as a complete response for any organization whose CI/CD or cloud credentials were exposed during the relevant windows. The actor's documented ability to establish persistence through new credential creation — generating a second access key on an existing user — means that revocation of the originally stolen credential alone does not restore a known-clean state. Full remediation requires rotation of all secrets accessible during the exposure window, audit of all IAM entities for unauthorized `CreateAccessKey`, `AttachUserPolicy`, or `PutUserPolicy` events, and review of CloudTrail for the discovery and persistence TTPs documented in the European Commission case.

4.15 Post-28 March TTP Summary

The victim-side reporting from late March onward adds several technically important TTPs that were absent or underdeveloped in the original March package-compromise narrative. The key technical progression from Phase 6 onward is that the earlier phases demonstrated how TeamPCP could steal secrets from trusted developer and CI/CD paths; the later reporting demonstrates what the actor did after that theft in real victim environments.

4.15.1 Documented TTPs

Programmatic Credential Validation

TruffleHog in verify mode (`--only-verified`) against live cloud and SaaS APIs, including AWS `sts:GetCallerIdentity` for key liveness and privilege-context identification. Validation began within hours of initial credential theft.

Rapid Transition from Theft to Use

Credential validation and cloud discovery beginning within hours to 24 hours of the initial compromise, indicating a near-automated post-theft triage workflow rather than manual processing of harvested credentials.

AWS Control-Plane Reconnaissance

Structured blast-radius mapping sequence: IAM enumeration (`ListUsers`, `ListRoles`, `ListAttachedUserPolicies`) to identify privilege edges and assumable roles; EC2 (`DescribeInstances`) for compute inventory; Lambda (`ListFunctions`) to identify functions potentially holding hardcoded secrets; and broader discovery across RDS, S3, and ECS for container infrastructure and task definitions.

Cloud Persistence Through Credential Expansion

Creation and attachment of a new AWS access key via `iam:CreateAccessKey` on an existing IAM user. This technique is more durable than simple credential reuse because it survives revocation of the originally stolen key, avoids `CreateUser` detection logic, and inherits existing user permissions without additional policy-attachment calls. Confirmed in the European Commission case.

Large-Scale Downstream Cloud Exfiltration

Confirmed volumes of 91.7 GB compressed (340 GB uncompressed) in the European Commission case across data belonging to 71 client organizations.

Operationally Distinctive Resource Naming

Strings such as "pawn" and "massive-exfil" in attacker-created cloud resource names, huntable in CloudTrail `requestParameters` fields by defenders with data event logging enabled.

4.15.2 ATT&CK Additions

- **T1195.002 — Compromise Software Supply Chain:** Primary initial access technique across all six upstream compromise phases.
- **T1552.001 — Credentials In Files:** Secrets harvested from CI/CD environment variable files and configuration files.
- **T1552.004 — Private Keys:** SSH keys and kubeconfig files harvested from CI/CD environments.
- **T1528 — Steal Application Access Token:** Confirmed operationalization of stolen AWS and SaaS tokens in victim environments.
- **T1078.004 — Valid Accounts: Cloud Accounts:** Use of compromised AWS API keys for direct cloud environment access and control-plane operations.
- **T1098 — Account Manipulation:** Creation and attachment of a new AWS access key to an existing IAM user for persistence. Confirmed in European Commission case.
- **T1087 / T1069 / T1580-style cloud discovery:** IAM, EC2, Lambda, S3, RDS, and ECS enumeration forming the cloud reconnaissance phase.

- **T1619 — Cloud Storage Object Discovery:** Applicable if actor enumerated S3 bucket contents before exfiltration, which the volume of confirmed exfiltrated data strongly suggests.
- **T1041 — Exfiltration Over C2 / Cloud Channel:** Confirmed large-scale cloud data exfiltration in European Commission case.

TLP:WHITE — TeamPCP Campaign Analysis — Phases 7–9 — April 2026